

AWS KMS: Key Management Service

Criptografia Gerenciada para Desenvolvedores

AWS Certified Developer Associate

Instrutor: Marlon Anesi

AWS KMS: Visão Geral e Tipos de Chave

KMS gerencia chaves de criptografia com controle de acesso (IAM + Key Policy), auditoria (CloudTrail) e rotação automática. Integrado com mais de 100 serviços AWS.

Tipos de KMS Keys (CMK - Customer Master Keys):

AWS Managed Keys

aws/[service]

- Criadas e gerenciadas pela AWS
- Rotação automática a cada ano
- Não é possível gerenciar ou usar fora do serviço
- Gratuitas. Ex: aws/s3, aws/lambda

Customer Managed Keys (CMK)

Voce gerencia

- Você cria, rotaciona e gerencia
- Key Policy obrigatória e customizável
- Rotação opcional (anual ou manual)
- Custo: \$1/mes por chave ativa

AWS Owned Keys

Multi-tenant

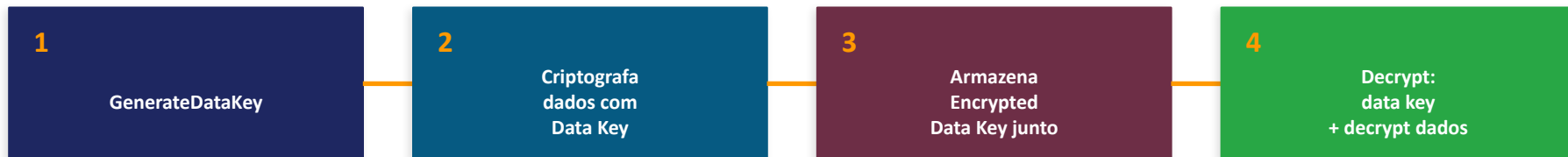
- Propriedade da AWS, compartilhadas
- Não visível ao cliente
- Não auditável no CloudTrail
- Mais barato (sem custo direto)

Operações KMS e Envelope Encryption

APIs principais do KMS:

Encrypt	Criptografa dados (max 4KB diretamente). Para mais de 4KB, use Envelope Encryption.
Decrypt	Descriptografa. Chave e identificada no ciphertext. Requer permissão kms:Decrypt.
GenerateDataKey	Gera Data Key (plaintext + encrypted). Usada no Envelope Encryption para dados grandes.
GenerateDataKeyWithoutPlaintext	Gera apenas a versão criptografada da data key. Para pre-gerar chaves.
ReEncrypt	Re-criptografa dados de uma chave para outra sem expor o plaintext.

Envelope Encryption (para dados > 4KB):



Key Policy e Rotação de Chaves

Key Policy (OBRIGATÓRIA para CMKs):

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "Enable IAM Access",
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::123456:root"
      },
      "Action": "kms:*",
      "Resource": "*"
    }
  ]
}
```

Regras Críticas da Key Policy:

- Key Policy é OBRIGATÓRIA (sem ela, nem root acessa)
- Statements de IAM policies só funcionam se Key Policy permitir
- Principal root: delega gerenciamento via IAM policies
- Pode ter separação: quem gerencia vs quem usa
- Cross-account: adicionar conta externa como Principal

Rotação de Chaves:

Tipo	Automatica	Manual (Rotation On Demand)
Frequencia	Anual (365 dias)	Qualquer momento (API RotateKeyOnDemand)
Disponibilidade	CMKs com key material AWS	CMKs com key material importado
Backlog	Chaves antigas mantidas para decrypt	Alias aponta para nova key; antiga desativada
Impacto nos dados	Dados antigos ainda descripto com versao antiga	Dados antigos precisam ser re-encryptados manualmente

Integração com Serviços AWS e Boas Práticas

S3 + KMS (SSE-KMS)

- Encrypt/decrypt automático ao salvar/ler
- kms:GenerateDataKey na escrita
- kms:Decrypt na leitura
- Bucket policy pode exigir SSE-KMS

Lambda + KMS (Env Variables)

- Variáveis de ambiente criptografadas
- Chave: aws/lambda (managed) ou CMK
- Lambda decripta na inicialização
- CMK: audit trail detalhado no CloudTrail

Boas Práticas:

- Use CMKs em produção para auditoria e controle. AWS Managed keys para simplicidade em dev.
- Habilite rotação automática para CMKs de longa duração (requisito de compliance comum).
- Limite kms:Decrypt apenas aos principals que realmente precisam descriptografar.
- Para dados > 4KB: sempre use Envelope Encryption com GenerateDataKey.

Pontos-chave para o Exame

1

Key Policy e OBRIGATÓRIA para CMKs

Sem Key Policy, nada funciona. Identity policy IAM só funciona se Key Policy delegar via root. Diferente de outros serviços.

2

Envelope Encryption para dados > 4KB

Chave KMS encripta Data Key. Data Key encripta os dados. Eficiente e econômico. GenerateDataKey e a operação chave.

3

Rotação: automática (anual) ou manual

Chaves antigas mantidas para decrypt. Dados antigos não precisam ser re-encriptados. Alias sempre aponta para versão atual.

LEMBRE-SE: KMS Encrypt > 4KB? -> Envelope Encryption com GenerateDataKey! Sem Key Policy? -> Ninguém acessa CMK!